Berner Fachhochschule
Haute école spécialisée bernoise
Bern University of Applied Sciences



IAM

Einführung und Grundbegriffe

Prof. Dr. Annett Laube, HS 2026, HSLU

Übersicht

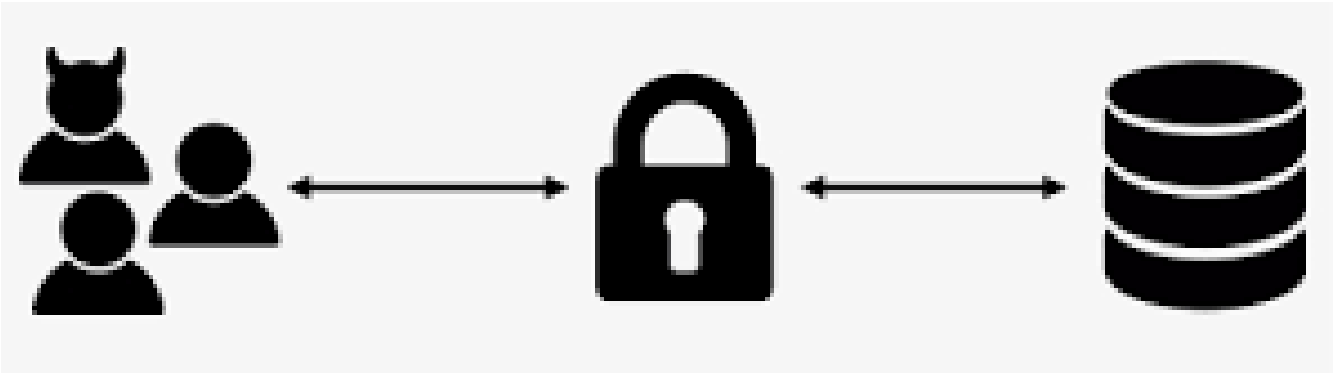
- Was ist IAM?
- Begriffe im IAM
- Identität
- Akteure im IAM

Übersicht

- Was ist IAM?
- Begriffe im IAM
- Identität
- Akteure im IAM

Identity and Access Management

- Dt.: **Identitäts- und Zugriffsverwaltung**
- **IAM** sind Prozesse, Policies und Technologien, um den *Zugriff* von *Subjekten* auf (geschützte) *Ressourcen* zu kontrollieren.



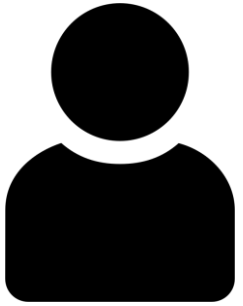
Identity and Access Management (IAM) is a security and business discipline that includes multiple technologies and business processes to help the right people or machines to access the right assets at the right time for the right reasons, while keeping unauthorized access and fraud at bay.
(Gartner Glossary, https://www.gartner.com/en/information-technology/glossary/identity-and-access-management-iam)

Identity and Access Management

IAM umfasst alles, was die folgenden Fragen bezüglich aller Teilnehmer (Personen, Maschinen, Services/Applications) in einem System beantwortet:

- Wer bist du?
- Woran erkennt man dich?
- Was darfst du und wozu bist du autorisiert?
- Wie werden die Grenzen deiner Autorisation durchgesetzt?

Subjekt



- Ist ein **Realweltobjekt** und hat spezifische *Eigenschaften*, die es identifizieren
- Existiert in verschiedenen Ausprägungen:
  - Natürliche Personen,
  - Gruppen von Subjekten,
  - Organisationen (juristische Personen),
  - Maschinen, Services, Dinge, KI-Agenten

- Ziel eines Subjektes (aus der Sicht IAM) ist der *Zugriff* auf eine Ressource.

- Subjekte werden im IAM-System als *Datenobjekte* (*elektronische/digitale Identitäten*) abgelegt.

- **Synonyme** für natürliche Person: Benutzer, User

Ressource



- Ist ein **Realweltobjekt**.
- Services oder Daten, auf die man zugreifen kann.
  - Dies schliesst physische Ressourcen, wie Gebäude und Anlagen, deren Benutzung über IT-Systeme gesteuert wird, ein.

- Das Ziel des **Ressource Owners** ist es, die Ressource vor unberechtigten Zugriffen zu schützen.
- Ressourcen gehören zu ***Relying Parties*** (Anwendungen/App/Systeme), die festlegen, wer wann und unter welchen Umständen auf ihre Ressourcen zugreifen dürfen.

- Ressourcen werden im IAM-System ebenfalls als Datenobjekte (digitales Abbild) abgelegt.

Arten von Ressourcen

- **öffentliche** (nicht schützenswerte) Ressourcen:
  - sind freizugänglich und benötigen zum Zugriff keinerlei Authentisierung.
  - Beispiele: Informative Webseiten (Lesezugriff) und öffentliche Daten.
- **versteckte** Ressourcen:
  - Diese Ressourcen erfordern keine Authentifizierung vor dem Zugriff, aber die Ressource ist nicht allgemein verfügbar, sondern nur einer Menge von Subjekten bekannt.
  - Beispiele sind Zugriffe auf Google-Docs oder Doodle-Links: Jeder, der die entsprechende URL kennt, kann auch auf die Ressource zugreifen.
- **schützenswerte** (nicht öffentliche) Ressourcen:
  - Diese Ressourcen erfordern eine erfolgreiche Authentifizierung und Autorisierung des zugreifenden Subjektes.
- **Im Kontext vom IAM sind i. allg. nur die schützenswerten Ressourcen von Interesse.**

Zugriff

- Als **Zugriff** werden alle Operationen bezeichnet, die man bei einer Ressource ausführen kann.
  - Typische Operationen sind Lesen, Schreiben (inkl. Ändern, Anlegen und Löschen) und Ausführen.



Zugriffskontrolle

- Engl.: **Access Control**
- Zugriffskontrolle ist **Überwachung** und **Steuerung** des Zugriffs auf Ressourcen.
- Das Ziel ist die Sicherstellung der Integrität, Vertraulichkeit und Verfügbarkeit von Informationen.



- Die Zugriffskontrolle erfolgt zur **Laufzeit** (auch Ausführungszeit genannt) statt, d.h. dann wenn ein Subjekt versucht, auf eine Ressource zuzugreifen.

Damit die Zugriffskontrolle möglich wird…

… müssen vorher (zur Definitionszeit) alle notwendigen Bedingungen geschaffen werden, damit zur Laufzeit bestimmt werden kann, ob ein Subjekt auf eine Ressource zugreifen darf.

Es müssen

- Digitale Abbilder der Subjekte und Ressourcen im IAM-System gepflegt werden.
  - Lifecycle-Prozesse: vom Onboarding über Mutationen bis zur Löschung.
- Zugriffsregeln definiert werden (wer darf wann und unter welchen Bedingungen was).
- Dazu kommen noch weitere Prozesse zum Betrieb, Support, Governance des IAM-Systems, …

Wiederholungsfragen / Diskussion

1. Warum brauchen wir IAM?

2. Warum ist IAM kein rein technisches Thema? Was gehört noch dazu?

3. Nennen Sie Beispiele aus Ihrem täglichen Leben, wo Sie IAM nutzen.

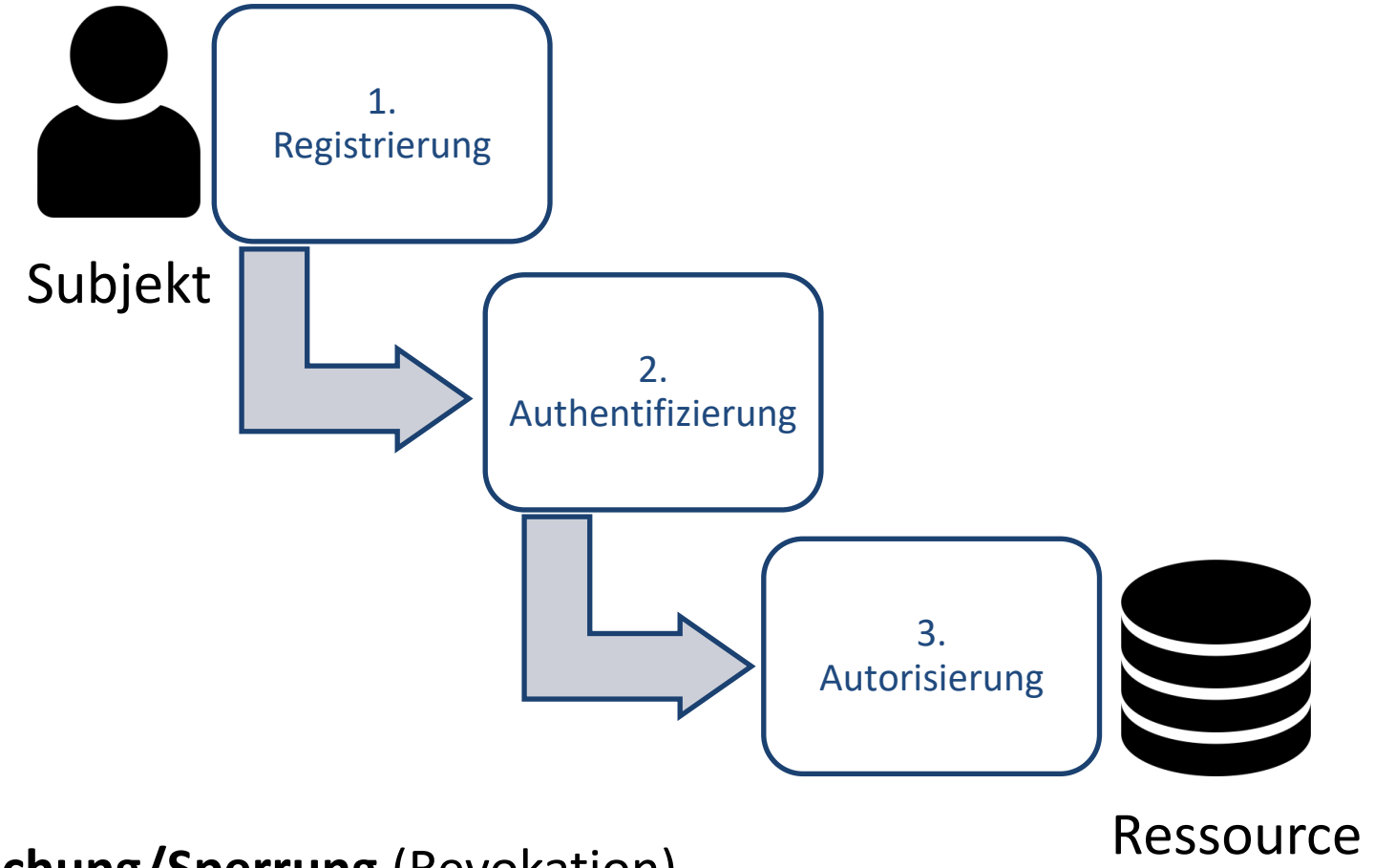
Übersicht

- Was ist IAM?
- Begriffe im IAM
- Identität
- Akteure im IAM

Basisprozesse

Die Registrierung (inkl. Identifizierung), die Authentifizierung und die Autorisierung von Subjekten sind die Kernprozesse eines IAM-Systems.

Ein **IAM-System** umfasst alle Prozesse und Systeme, um Subjekten den Zugriff auf die Ressourcen zu ermöglichen.



Weitere Prozesse sind **Mutation** und **Löschung/Sperrung** (Revokation).

Registrierung

- Für die **Registrierung** eines Subjektes muss dessen Teil-Identität (partielle Identität) im Kontext der verwaltenden Organisation erstellt werden.
  - Es wird eine digitale Identität erstellt, sowie Attribute und Rollen zugeordnet.
    - Meist werden Attribute überprüft, sonst gelten sie als s*elbstdeklariert*.
  - Oft wird das Subjekt *identifiziert*.
  - Der digitalen Identität werden *Authentifizierungsmittel* zugeordnet und an das Subjekt *gebunden*.
- Synonyme: Onboarding, Erstellen des Benutzer-Kontos (user account)

Identifizierung/Identifikation


WER IST DER TYP?
WER IST DER TYP?
WER IST DER TYP?

Überprüfung der Attribute

- Die Attribute eines Subjektes werden mit Hilfe von
  - **Beweismitteln** oder
  - technischen Prozessen (z.B. E-Mail-Verifikation, SMS-Code an Mobilnummer, Brief mit Aktivierungscode, …)

  überprüft.

Beweismittel



- Ein **Beweismittel** ist ein Dokument oder Objekt aus einer verlässlichen Quelle, das Angaben zum Antragsteller enthält. Es kann zur Überprüfung einer Identität oder von Attributen eines Subjektes verwendet werden.
- Ein Beweismittel muss den Namen des Antragsstellers enthalten. Es kann zusätzlich einen eindeutigen Identifikator, körperliche und biometrische Merkmale aber auch beliebige andere Angaben des Antragstellers enthalten. Es sollte Sicherheitsmerkmale enthalten, die ein Reproduzieren erschweren.

- Beispiele:
  - **Identitätsdokumente**
  - Beglaubigte Urkunde
  - Kreditkarten
  - Fahrausweis

Verlässliche Quelle

- Eine verlässliche Quelle ist eine beliebige Informationsquelle, welche bezogen auf eine konkrete Situation, z.B. bei der Identifizierung einer Person, als vertrauenswürdig betrachtet wird.
- [eIDAS 2015/1502]: „Verlässliche Quelle“ ist eine beliebige Informationsquelle, die auf verlässliche Weise präzise Daten, Informationen und/oder Beweismittel bereitstellt, die zum Identitätsnachweis verwendet werden können.
- [eIDAS 2024/1183]: „Authentische Quelle“ ist ein Datenspeicher oder ein System, der bzw. das unter der Verantwortung einer öffentlichen Stelle oder privaten Einrichtung betrieben wird, Attribute zu einer natürlichen oder juristischen Person oder zu einem Objekt enthält und bereitstellt und als eine primäre Quelle für diese Informationen gilt oder im Einklang mit Unionsrecht oder nationalem Recht — einschließlich der Verwaltungspraxis — als authentisch anerkannt wird.
- Verlässliche/ Quellen können viele verschiedene Formen haben:
  - Register, Urkunden, öffentliche Stellen/Behörden usw.

eIDAS (electronic IDentification, Authentication and trust Services /elektronische Identifizierung und Vertrauensdienste für elektronische Transaktionen) bezeichnet die Verordnung des Europäischen Parlaments und des Rates über elektronische Identifizierung und Vertrauensdienste für elektronische Transaktionen im Binnenmarkt.

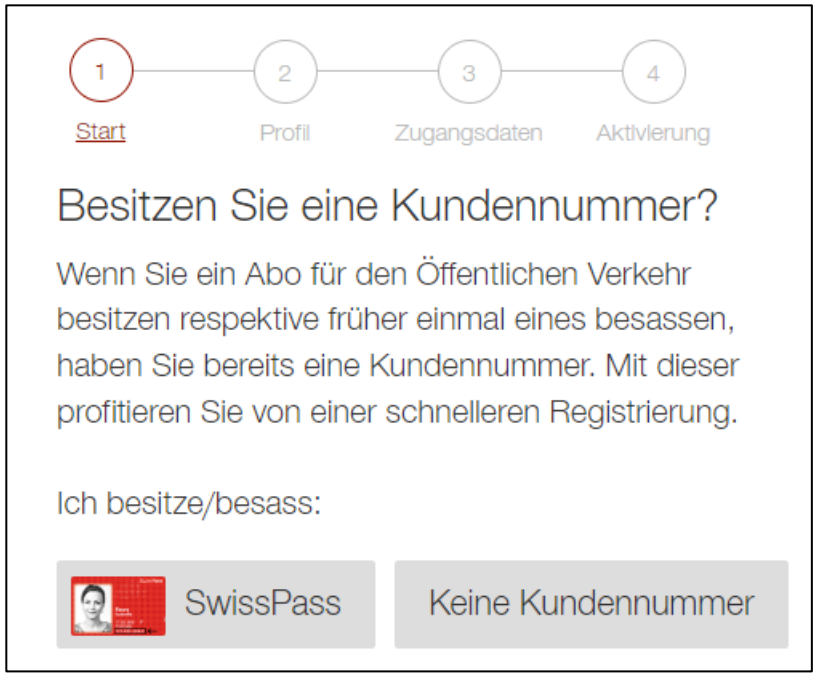
Beispiel: SwissPass Registrierung

1. Auswahl des Registrierungsprozesses

2. a) Angaben vom SwissPass
   b) Angabe von Namen, Geburtsdatum, Adresse (wird geprüft)

3. E-Mail-Adresse und Passwort

4. Aktivierung über E-Mail-Link (gleichzeitig Überprüfung der E-Mail-Adresse)



Authentifizierung



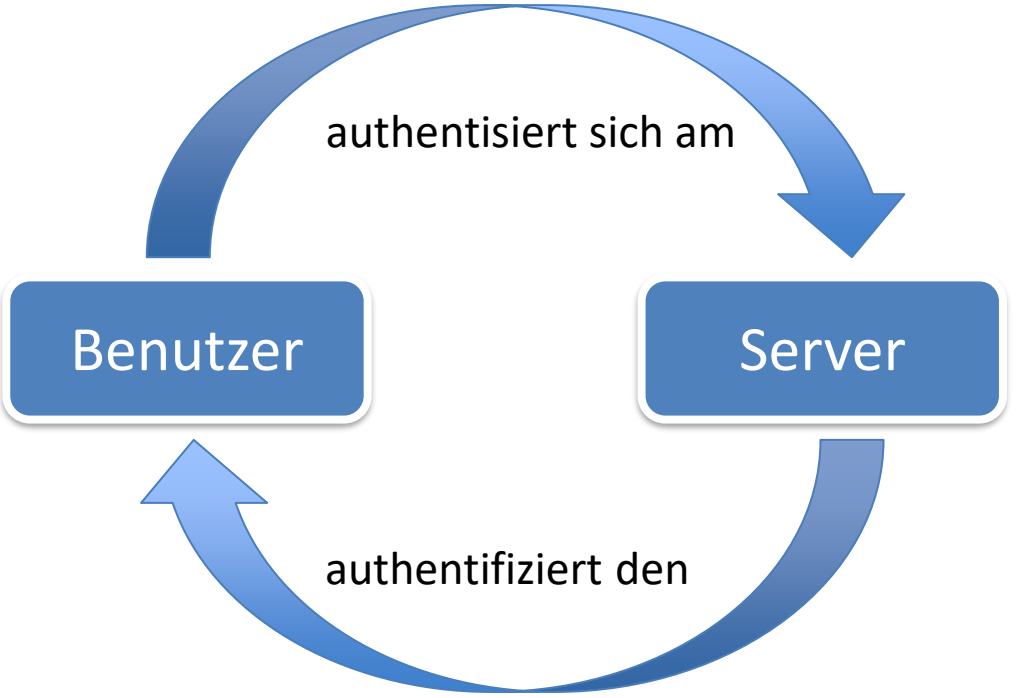
- **Authentifizierung** ist der wiederkehrende Prozess der Überprüfung der Zugehörigkeit einer (Teil-)Identität zu einem Subjekt.
  - Prozess zur Überprüfung der behaupteten (digitalen) Identität
- Dabei wird **verifiziert**, ob die erfassten persönlichen **Identitätsnachweise** (Credentials) mit einer gewissen Sicherheit zur präsentierten (Teil)Identität gehören.
- Die Stärke einer Authentifizierung ist abhängig von der Stärke der Bindung der (Teil-)Identität zum Subjekt und damit von der Anzahl und dem Typ der **Authentifizierungsmittel**.

- Synonyme: Authentifikation, Authentisierung, (Login)

Authentifizierung/Authentisierung

- *Authentisierung* ist der Vorgang des Nachweises der eigenen Identität.

- *Authentifizierung* ist der Vorgang der Überprüfung einer behaupteten Identität.



Autorisierung

- Ob dem *authentifizierten* Benutzer der Zugriff zu einer Ressource gewährt werden darf, entscheidet die Applikation (Relying Party) im Rahmen der ***Autorisierung***.

- Die entsprechenden Zugriffregeln müssen hinterlegt sein und zur Laufzeit angewendet werden.
  - Am häufigsten wird heute *Role-based Access Control (RBAC)* und *Attribute-based Access Control (ABAC)* eingesetzt.
  - Als Standard zur Beschreibung der Regeln (Policies) wird *XACML* eingesetzt.
  - Beispiel: jeder Mitarbeiter hat Zugriff auf seine Personalakte; ein Vorgesetzter hat Zugriff auf die Personalakten aller seiner Mitarbeiter.

- Synonyme: Zugriffskontrolle, Benutzerberechtigung

Least Privilege - Prinzip



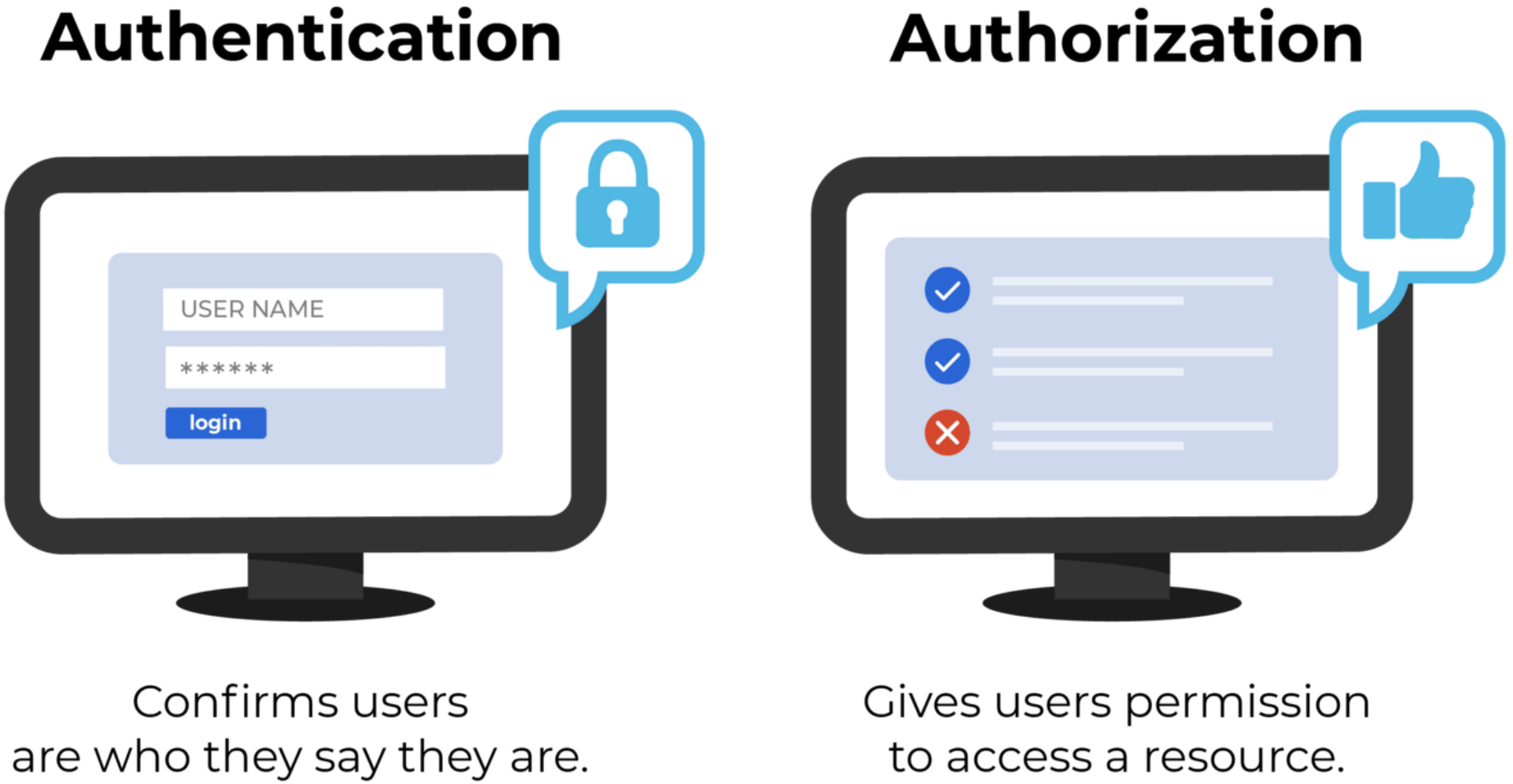
Least-Privilege-Prinzip: eine authentifizierte Identität erhält nur die Zugriffsrechte, die für die Erfüllung einer konkreten Aufgabe erforderlich sind (Need-to-Know-Prinzip).

- **So viel Zugriff wie notwendig, so wenig Zugriff wie möglich – für genau die Aufgabe, die Ressource und den Zeitpunkt, für die der Zugriff erforderlich ist.**

Prinzipien

- Feingranulare Ressourcen
- Minimale kontextabhängige Berechtigungen (Einschränkung von Aktionen, Umfang, Zeit und Kontext)
- Just-in-Time und Just-enough Access
- Nachvollziehbarkeit gewährleisten

Authentifizierung vrs Autorisierung



Wiederholungsfragen / Diskussion

1. Differenzieren Sie die folgenden Begriffe:
   - Registrieren,
   - Identifizieren,
   - Authentifizieren,
   - Autorisieren.

2. Warum braucht man Beweismittel zur Überprüfung von Attributen bzw. zur Identifizierung? Welche Beweismittel sind geeignet?

Übersicht

- Was ist IAM?
- Begriffe im IAM
- Identität
- Akteure im IAM

Identität (im IAM)

- Eine Identität beschreibt Eigenschaften eines Subjektes.
- Die Identität repräsentiert das Subjekt eindeutig in einem Namensraum.
- Eine Identität hat einen **Identifikator** (eindeutige Kennung), meist zusammen mit einer Menge von zusätzlichen Attributen, welcher innerhalb eines Namensraumes eindeutig einem Subjekt zugewiesen werden kann.

Digitale Identität

- Eine **digitale Identität** ist eine digitale Repräsentation von Eigenschaften eines Subjekts.
  - ist ein **Datenobjekt** für ein Subjekt
- Ein Subjekt kann mehrere digitale Identitäten haben.
  - Digitale Identitäten können verlinkt werden (*Identity-Linking*)
- Eine digitale Identität ist an ein Authentifizierungsmittel gebunden, das das Subjekt verwenden kann, um sich damit zu authentifizieren.

- **Synonyme**: Digital Identity, Elektronische Identität (E-Identity), Electronic Identity, Benutzerkonto (User account)

Warum braucht es Digitale Identitäten?

- **Authentifizierung und Autorisierung:**
  Digitale Identitäten ermöglichen die eindeutige Zuordnung von Subjekten und damit die Zugriffskontrolle
- **Personalisierung:**
  Inhalte, Dienste und Berechtigungen können auf Personen und ihre jeweiligen Bedürfnisse zugeschnitten werden.
- **Vertrauen:**
  Digitale Identitäten können helfen, Betrug, Identitätsdiebstahl und unbefugte Zugriffe zu verhindern.
- **Sicherheit:**
  Digitale Identitäten ermöglichen sichere Kommunikation, sicheren Datenaustausch und sichere Transaktionen.
- **Compliance:**
  Digitale Identitäten unterstützen die Einhaltung gesetzlicher und regulatorischer Anforderungen, z. B. bei Datenschutz und Identitätsprüfung.

Beispiel - Alice

Reale Welt



Subjekt

Eigenschaften

- Alice Baumann
- Geb. am 16.4.1996 in Bern
- Studiert an der HSLU
- Hat die E-Mail-Adresse:
  - alice@bluewin.ch
- Hat braune Haare
- …

Identität

Digitale Welt

Identifikator / Benutzername	alice
Name	Baumann
Vorname	Alice
Geburtsdatum	16.04.1996
Geburtsort	Bern
Geschlecht	weiblich
Student?	True
E-Mail	alice@bluewin.ch
Passwort	******

Attribute

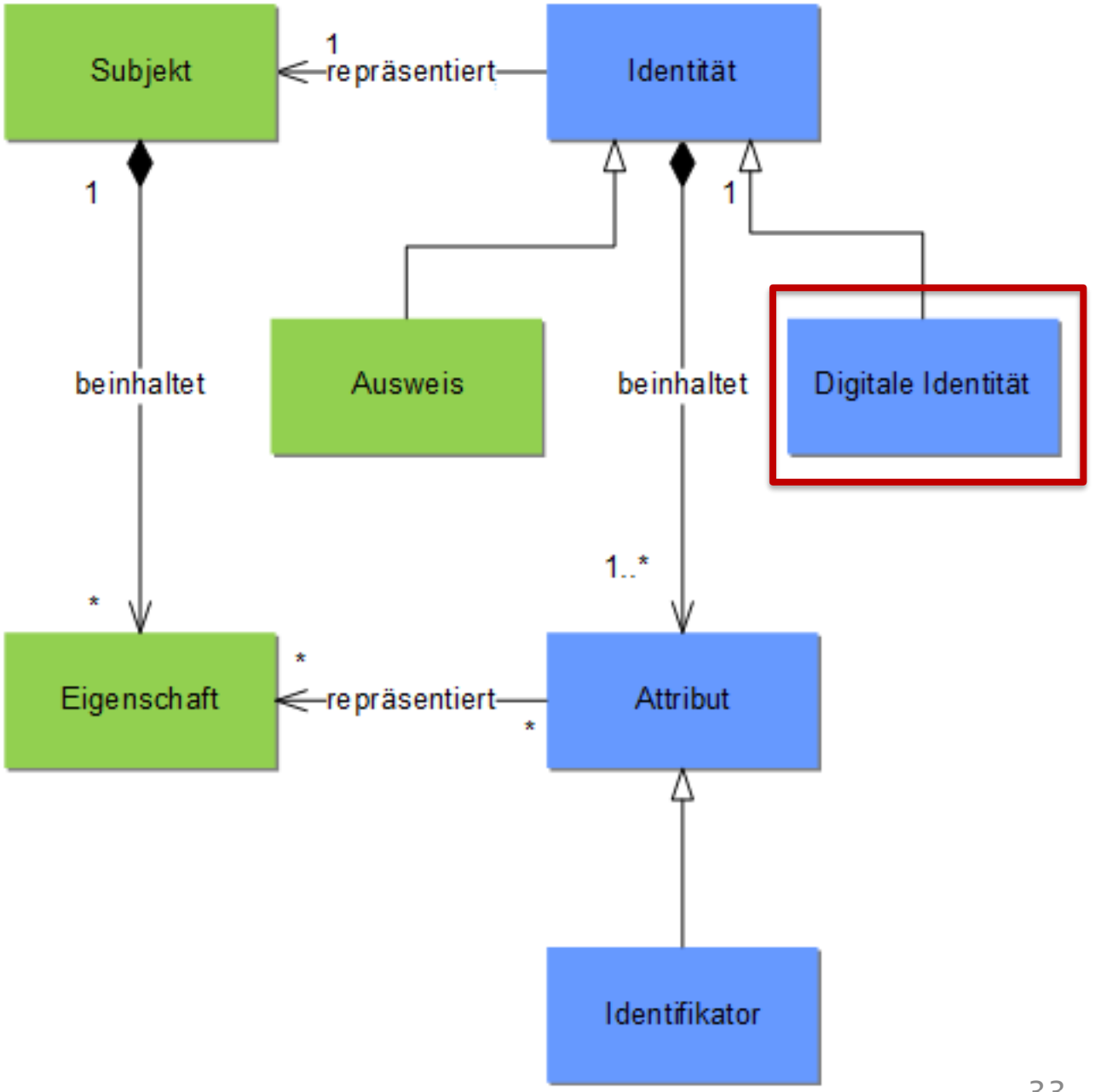
Digitale Identität

Link zum Auth-Mittel

Informationsmodell (UML)

- Reale Welt
- Digitale Welt

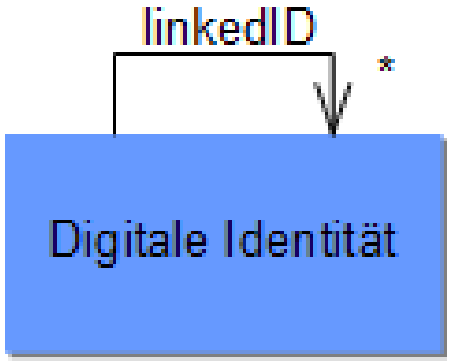
Für IAM sind nur die **digitalen Identitäten relevant**, mit denen eine Authentifizierung möglich ist. D.h. die verwendeten digitalen Identitäten müssen einen Link zum Authentifizierungsmittel des Subjekts besitzen.



Verlinkung von Identitäten

- Identitäten von Benutzern können verlinkt sein und dann oft alternativ verwendet werden

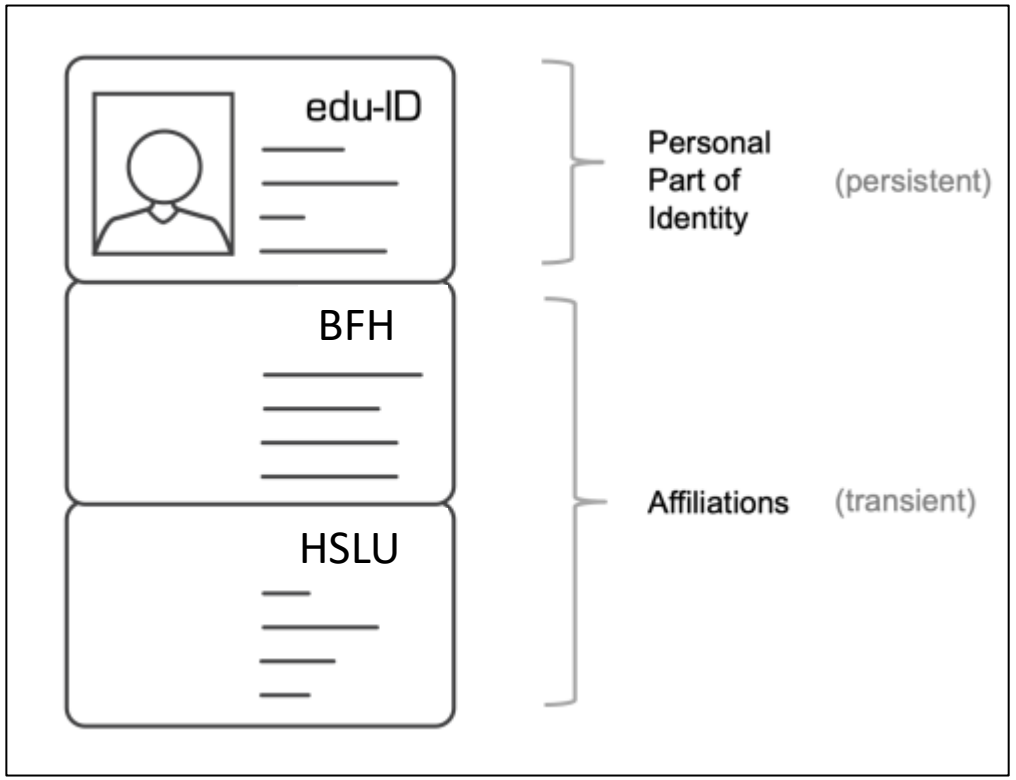
- Beispiele:
  - Zoom – HSLU-Account
  - Digitec/Galaxus – Google/Meta/Apple
  - HSLU – Switch edu-ID
  - …



Identity Linking bei Switch edu-ID

- Jeder Benutzer hat ein eigenes edu-Id-Konto.
- Wenn ein Benutzer Mitglied einer Universität wird, wird dem edu-ID-Konto eine Zugehörigkeit (*affiliation*) hinzugefügt.





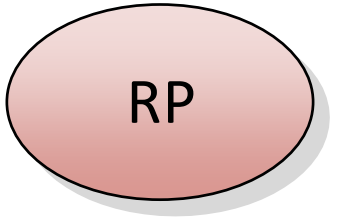
Übersicht

- Was ist IAM?
- Begriffe im IAM
- Identität
- Akteure im IAM

Akteure

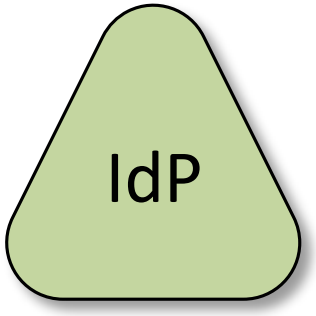
- Ein IAM-System kennt 3 verschiedene Hauptakteure:
  - **Subjekt**
  - **Relying Party**
  - **IAM-Dienstanbieter** mit verschiedenen Rollen
    - Identity Provider (IdP)
    - Registrierungsstelle / Registration Authority (RA)
    - Vermittler

Relying Party (RP)



- Die **Relying Party (RP)** ist eine Anwendungen (oder App, System, ..), die Interessen der *Ressource* im IAM-System vertritt.
  - Sie nutzt *IAM-Services* und verarbeitet so Informationen von *IAM-Dienstanbietern* für den **Schutz ihrer *Ressourcen***.
  - Sie legt **Zugriffsregeln** fest, welche *Subjekte* unter welchen Bedingungen auf ihre *Ressourcen* zugreifen dürfen.
  - Sie braucht zur Prüfung der *Berechtigung* eines Ressourcenzugriffs zur *Laufzeit* nähere Informationen zu einem *Subjekt,* d.h. dessen digitale Identität mit den berechtigungsrelevanten Attributen, und den Kontext des *Zugriffs* (Lokation, Zeitpunkt, *Vertrauensstufe* etc.).
- **Synonyme**: Informationsbezüger, Informationskonsument, Identitätskonsument, Lösungsanbieter/dienstanbietende Organisation, SAML Service Provider (SP), Vertrauende Partei, Verifier

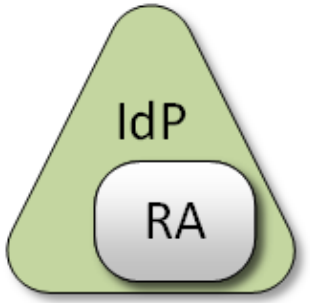
Identity Provider (IdP)



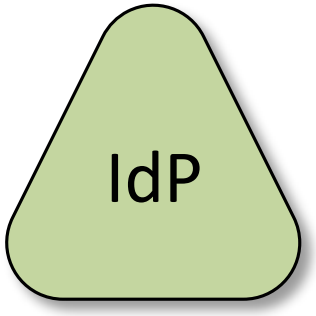
- Der **Identity Provider (IdP)** gibt digitale Identitäten heraus und verwaltet sie.

- Der **Identity Provider (IdP)** vergibt, erneuert, ersetzt und revoziert benutzerfreundlich *Authentifizierungsmittel* für *Subjekte*
  - Er erstellt, erhebt oder vergibt Authentifizierungsmerkmale (z. B. Passwörter, Authentisierungszertifikat) oder bindet Authentifizierungsmittel an eine Identität des Subjektes (mit Hilfe von sog. Credentials).
  - Der IdP stellt die Vertraulichkeit, Integrität und Verfügbarkeit der Credentials sicher.

- Zu einem IdP gehört meist eine oder auch mehrere *RA.*
  IdPs werden dann auch als **Identitätsdienste** bezeichnet.



Identity Provider (IdP)



Der **IdP** stellt einen *Authentication Service* zur Verfügung, der

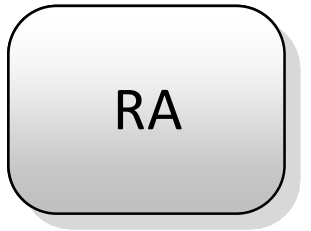
- die Subjekte zeitnah **authentisiert**,
  - Er überprüft dabei die behauptete *Identität* des *Subjekts,*
  - indem der die vom Subjekt präsentierten *Authentifizierungsmittel* mit Hilfe der hinterlegten *Credentials* verifiziert.

- und – bei positivem Ausgang der Prüfung –
  - eine *Authentifizierungsbestätigung* ausstellt und
  - optional können Attribute bestätigt werden (*Attributbestätigung*).

Attribute vom Identity Provider

- Zu den Standard-Attributen eines IdP gehören:
  - Identifier (z.B. Benutzername)
  - E-Mail
  - Name, Vorname
  - Geburtsdatum,
  - …

Registration Authority (RA)



- Die **Registration Authority (RA)** ist verantwortlich für die **Registrierung** und **Identifizierung** und autorisiert im Erfolgsfall die Erstellung einer digitalen Identität.

- Die RA erfasst und prüft die *Identität* und *Attribute* der Subjekte.
  - **Identifizierung**: Wer bist du?
    → Feststellung der Identität gemäss der gewünschten Vertrauensstufe
  - **Verifizierung**: Stimmen deine Angaben?
    → Prüfung der Identität und ihrer Attribute anhand von Beweismitteln
  - **Registrierung**: Wir nehmen dich ins System auf.
    → Erfassung der verifizierten Identität und Attribute

- **Synonyme**: Registrierungsstelle, Identifizierungsstelle

Wiederholungsfragen / Diskussion

1. Kennen Sie Identity Provider?
   - Welche?
   - Kennen Sie IdPs in der Schweiz oder Europa?

2. Nennen Sie Beispiele für Ihnen bekannte Registration Authorities?

Vielen Dank !!

Noch Fragen oder Bemerkungen?

